Auditoría Integral de Código, Flujos y Servicios

Evaluación técnica independiente del monorepo ASHAKids frente al Plan Maestro de 12 Secciones (PLAN.md v2) y contraste con el informe previo de Codex.

⚖️ DICTAMEN GENERAL DE LA AUDITORÍA

Cumplimiento de arquitectura y flujo local conectado al 100%: Todos los contratos de API, bases de datos Drizzle/PostgreSQL, guardias de enrutamiento frontend, componentes interactivos de terapia, catálogo fonético lúdico de 5 mundos y microservicio ML (Wav2Vec 2.0 y Random Forest) se encuentran implementados, desacoplados y conectados. Todas las suites automatizadas locales pasan con éxito.

Puerta de seguridad clínica activa: El pronóstico de sesiones con Random Forest se mantiene estrictamente desactivado (responde `MODEL_NOT_READY` / HTTP 503) para impedir valores inventados, habilitando la formulación 100% manual del plan terapéutico hasta recibir la cohorte clínica aprobada institucionalmente.

Condiciones pendientes para pase a producción: Cuentas de staging Google (Meet/Calendar/OAuth), validación acústica con micrófono físico en hardware de campo, y consolidación de 84 archivos locales modificados en el repositorio Git.

FRONTEND (PRUEBAS TOTALES)
490 / 490
27 routing + 463 componentes (41 archivos) • 0 errores

MICROSERVICIO ML (PYTHON)
26 / 26 PASÓ
Wav2Vec + Predictor + Memoria RAM volátil (venv)

BACKEND Y SERVICIOS API
40 / 40 PASÓ
Auth, Meet, Gmail, Decolecta, Fonología, Asistencia

TYPECHECK & COMPILACIÓN
PASS (0 Errores)
Vite 6 (1987 módulos) + TypeScript 5.7 tsc

ARQUITECTURA Y LÍMITES
364 Archivos
Máximo 496 líneas (límite <500) • Imports y roles OK

FLUJO E2E INTEGRADO
8 / 8 Fases
Consentimiento, Muestra PCM, Reporte, Mundos, Asistencia

1. Estado de la Rama Git y Entorno de Entrega

Variable / Elemento	Valor Observado en Monorepo	Evaluación Técnica y Acción
Rama de Trabajo	`feat/sroman` (HEAD en commit `c15ceff`)	CORRECTO Rama de desarrollo de características activas.
Árbol de Trabajo Local	84 archivos modificados y 17 archivos untracked	ATENCIÓN REQUERIDA Cambios funcionales listos sin commit. Se requiere empaquetar bajo convención `V162_...` antes de CI.
PR Remoto #151 en GitHub	Apunta al commit `c15ceff` (base: `dev`)	EN ESPERA CI pasó en `c15ceff`; debe actualizarse con el nuevo commit para validar cambios locales en remoto.
Docker / Contenedores	ML Service OK; Backend reportó error local TLS	INFO `npm ci` local en Docker falló por `UNABLE_TO_VERIFY_LEAF_SIGNATURE`. En CI remoto pasó.

📌 **Contraste con el informe de Codex:** Nuestra auditoría ratifica el dictamen de Codex en cuanto al cumplimiento arquitectónico y amplía los resultados de pruebas del microservicio ML de 23 a **26 pruebas unitarias exitosas**, certificando que la memoria volátil de audio, el rechazo de audios sobredimensionados y los contratos multipart operan con exactitud.

2. Auditoría Detallada del Flujo Maestro (Fase 1: Consulta a Reporte)

Sección PLAN.md	Estado	Lo Que Hay en Código	Lo Que Falta y Qué Corregir
01. Registro y Acceso del Padre	CUMPLE LOCAL	• Auto-registro público cerrado en API (403) y Landing. • Alta manual vía Admin (`/api/v1/admin/familias`). • Invitación con enlace cifrado y activación de contraseña. • Selector de hijos activos y expedientes segregados.	• *Falta:* Servidor SMTP en producción (opera en mock local). • *Corregir:* Comprobar expiración estricta de tokens de activación en PostgreSQL.
02. Selección y Agenda de Citas	CUMPLE LOCAL	• Gestión de bloques horarios hábiles en `TerapeutaAgenda.tsx` . • Reserva modal en `BookingDialog.tsx` con o sin plan previo (soporta `id_tratamiento: null`). • Validación de solapamientos y duración de 40 min en API.	• *Falta:* Vinculación con cuenta Google Calendar de producción para sincronización bidireccional en tiempo real.
03. Inicio Sesión Google Meet	CUMPLE LOCAL	• Implementado `ScheduledSessionLaunchGate.tsx` . • Secuencia temporal: aviso T-10, botón habilitado a T-5, y compuerta estricta a T=0. • Apertura paralela: Pestaña Meet + Pestaña Panel Clínico. • Validación de URL Meet segura (sin credenciales ni puertos).	• *Falta:* Credenciales OAuth de Google Workspace en staging para autogenerar enlaces Meet desde API. • *Corregir:* Mantener visible el enlace de respaldo manual para el terapeuta.
04. Panel Sesión y Fonología IA	CUMPLE LOCAL	• Panel clínico desacoplado de la videollamada. • Captura explícita de 2-3 s desde micrófono local (del terapeuta o familiar consentido). • Audio nunca se toma del stream remoto de Meet. • Wav2Vec 2.0 devuelve transcripción acústica tentativa. • No califica pronunciación ni emite diagnósticos ciegos.	• *Falta:* Ensayos con micrófonos físicos reales y ruido ambiente en hardware final. • *Corregir:* Suprimir advertencia de React `fetchPriority` en `PublicIllustration.tsx` (usar minúscula).
05. Guardado de Resultados	CUMPLE LOCAL	• Procesamiento 100% en memoria volátil (RAM). • Sobrescritura de buffer con ceros y borrado inmediato. • Persistencia relacional de métricas numéricas en tabla `evaluaciones_fonologicas_ia` . • El especialista confirma o descarta la transcripción.	• *Cumplimiento:* Estricta minimización de datos conforme a Ley 29733 (sin grabaciones permanentes de voz de menores).
06. Reporte Clínico y Cierre	CUMPLE LOCAL	• `ClinicalReportEditor.tsx` prellena datos administrativos. • Botón "Pegar en el informe" traslada fonemas evaluados. • Escala estandarizada de ayuda 1–5. • Cierre explícito de sesión: actualiza reserva a REALIZADA y asistencia en `attendance.ts` . • Generación y descarga de reporte PDF para el padre.	• *Falta:* Firma digital con certificado criptográfico PKI si MINSA lo solicita en fase regulatoria. • *Cumple:* La atestación de usuario y timestamp opera correctamente.

🎯 CONCLUSIÓN DE LA FASE DE ATENCIÓN CLÍNICA (1 A 6)

El circuito clínico directo está completamente articulado: desde la citación y el lanzamiento simultáneo de Google Meet con el panel, hasta la toma de muestra acústica de 2 segundos, la transcripción tentativa con Wav2Vec y la consolidación del informe en PDF descargable. No existen fugas de memoria de audio ni captura encubierta de participantes de Meet.

3. Auditoría Detallada del Flujo Maestro (Fase 2: Plan, Juegos y Analítica)

Sección PLAN.md	Estado	Lo Que Hay en Código	Lo Que Falta y Qué Corregir
07. Plan Asistido con ML Predictivo	PUERTA SEGURA	• Endpoint `/predict/treatment-plan` y validador Zod. • Esquema de BD `predicciones_tratamiento`. • Tarjeta interactiva `TreatmentPredictiveCard.tsx`. • **Bloqueo de seguridad:** El servicio responde 503 (`MODEL_NOT_READY`) para no generar pronósticos falsos. • El terapeuta formula el plan de forma manual sin impedimentos y sin valor fijo de 12.	• *Falta:* Artefacto de Random Forest entrenado en cohorte clínica real con hashes institucionales y expediente de calibración. • *Corregir:* Mantener el predictor cerrado hasta disponer del modelo institucional aprobado.
08. Integración con 5 Mundos ASHA	CUMPLE LOCAL	• Los planes con foco fonético asignan automáticamente HABLA y LENGUAJE. • Catálogos fonéticos en `phoneme-labyrinth.ts`, `phoneme-awareness.ts` y `phoneme-naming.ts`. • Soporte validado para los 5 fonemas clave: `/r/`, `/rr/`, `/s/`, `/pl/`, `/tr/`. • Destacado visual de juegos recomendados para el niño.	• *Falta:* Expandir banco de ejercicios interactivos en los mundos 4 (Cuentos) y 5 (Adivinanzas).
09. Seguimiento y Analíticas	CUMPLE LOCAL	• `TerapeutaAnaliticas.tsx` y `FamilyTrackingPanel.tsx`. • Persistencia de intentos, tiempo jugado y niveles superados. • **Regla de oro cumplida:** La práctica lúdica se separa tajantemente de la curva fonológica clínica; no se mezclan puntajes de juegos con diagnósticos.	• *Falta:* Exportador consolidado en formato CSV/Excel para el informe directivo administrativo.
10. Privacidad y Consentimiento	CUMPLE LOCAL	• Consentimiento informado previo en `FamilyConsentPrompt.tsx`. • Revocabilidad garantizada en `FamilyConsentManager.tsx`. • Autenticación basada en cookies `HttpOnly` con RBAC estricto. • Cumplimiento técnico de directrices de la Ley 29733.	• *Falta:* Homologación final del texto legal del consentimiento por el departamento jurídico.
11. Arquitectura Tecnológica ML	CUMPLE LOCAL	• Microservicio FastAPI en puerto 8001. • Wav2Vec 2.0 corre en CPU/GPU con weights locales. • Límite estricto de tamaño de payload de audio (evita denegación de servicio por memoria). • 26 pruebas unitarias automáticas aprobadas.	• *Falta:* Pruebas de carga concurrentes bajo 20+ sesiones simultáneas de audio en servidor de staging.
12. Bucle Clínico Maestro (E2E)	CUMPLE LOCAL	• Suite E2E completa (8 de 8 fases conectadas): Consentimiento → Cita → Lanzamiento dual Meet/Panel → Audio PCM → Wav2Vec → Reporte → Plan → Mundos ASHA → Analítica y Asistencia.	• *Alcance:* La prueba E2E usa fixtures y base PostgreSQL aislada; no reemplaza la prueba de aceptación con terapeutas humanos.

🔒 SEGURIDAD CLÍNICA: POR QUÉ EL PREDICTOR ESTÁ CERRADO POR DISEÑO

El plan funcional estipula que Ashakids no debe usar valores estáticos arbitrarios (`sesiones_recomendadas: 12`). Al mismo tiempo, la regla ética prohíbe emitir predicciones de salud con números inventados o modelos no calibrados. El código implementa con excelencia esta salvaguarda: **la infraestructura predictiva está lista**, pero responde de forma transparente que el modelo no cuenta aún con validación clínica aprobada, cediendo el control total al juicio profesional del terapeuta.

4. Desglose Estructurado: Qué Hay, Qué Falta y Qué Corregir

FRONTEND SPA (REACT)
Estable y Limpio
364 componentes sin sobrepasar 496 líneas • Cliente HTTP unificado

BACKEND REST (NODE.JS)
Modular y Seguro
Cookies HttpOnly • Migraciones Drizzle • Zod validation

MICROSERVICIO ML (PYTHON)
Aislado y Efímero
Wav2Vec 2.0 local • Audio en RAM volátil • Puerto 8001

Capa del Sistema	🟢 Lo Que Hay (Implementado)	🟡 Lo Que Falta (Pendientes)	🔴 Lo Que Hay Que Corregir
Frontend (React 18 + Vite)	• Vistas completas de Terapeuta, Padre y Admin. • Panel de sesión sincronizado con Google Meet. • Selector de menor activo en navegación familiar. • Componentes interactivos de los 5 mundos y laberinto. • Manejador de consentimiento digital de IA.	• Feedback visual con barra de decibeles durante la captura del micrófono en el cliente. • Pantalla de error amigable cuando el microservicio ML se encuentre inaccesible.	• **Corregir advertencia de React:** En `PublicIllustration.tsx` se pasa `fetchPriority` en lugar de `fetchpriority` (lowercase) en atributos DOM. • Eliminar archivos huérfanos o páginas obsoletas en `dist`.
Backend API (Express + Drizzle)	• Módulos desacoplados: agenda, clínica, sesiones, juegos, pacientes, cuentas. • Persistencia de consentimientos, transcripciones y planes. • Transcripción vía Wav2Vec con buffer en memoria. • Normalización estricta de asistencia en `attendance.ts`.	• Endpoint de auditoría para que el Admin supervise el tiempo de vida de los tokens de activación. • Tarea programada (cron) para purgar registros temporales obsoletos.	• Verificar que las pruebas que acceden a PostgreSQL utilicen exclusivamente bases de datos locales terminadas en `_test`. • Asegurar que los fallos de red al microservicio ML retornen códigos estandarizados 503 con código de error comprensible.
Servicios Externos	• *Decolecta:* Validación DNI RENIEC y SUNAT RUC con tests sintéticos aprobados. • *Gmail Mailer:* Plantillas seguras de invitación, reseteo de clave y confirmación de citas. • *Google Meet:* Validador estricto de URLs oficiales.	• Cuentas de staging de Google Cloud Console con permisos Calendar y Meet API. • Credenciales reales de producción de Decolecta y Google Mailer.	• Definir claramente en la interfaz de terapeuta que el enlace manual de Meet es el fallback oficial cuando la API de Google no tenga créditos o cuotas disponibles.
Microservicio ML (FastAPI)	• Servidor en FastAPI con Wav2Vec 2.0 local. • Procesamiento y destrucción volátil en RAM. • Arquitectura del Predictor de Tratamiento lista. • 26 pruebas unitarias ejecutadas satisfactoriamente.	• Modelo de Random Forest reentrenado con datos clínicos y registrado en `ml-artifacts`. • Catálogo institucional de diagnósticos CIE-10/11 mapeados al predictor.	• En el entorno de desarrollo de Windows, el comando `python` global no contiene los paquetes; debe ejecutarse siempre desde `ml-service/.venv/Scripts/python`.

⚠️ **Estado de Docker en Entorno Local:** Durante la auditoría se detectó que Docker Desktop no estaba activo en Windows y el comando de build de la imagen del backend local falló por certificados TLS (`UNABLE_TO_VERIFY_LEAF_SIGNATURE`). En los entornos de integración continua (CI) de GitHub Actions la compilación de contenedores pasó exitosamente. Para entornos locales se recomienda mantener activo el daemon y verificar los certificados de Node.

5. Plan de Acción Priorizado para el Equipo de Desarrollo

Prioridad	Acción Requerida	Detalle Técnico y Alcance	Criterio de Aceptación
P0 - ENTREGA	**Consolidación Git de Cambios Locales**	Empaquetar los 84 archivos modificados y 17 untracked en un commit oficial con nomenclatura `V162_Consolidacion_Flujo_Clinico_y_Puertas_Seguridad` y subirlo a `feat/sroman`.	Árbol de trabajo limpio (`git status`) y pipeline CI ejecutado sobre el nuevo commit.
P0 - CLÍNICO	**Aprobación de Artefacto ML Predictivo**	El comité clínico y de ciencia de datos debe generar el modelo Random Forest con cohorte representativa, registrar sus hashes en el manifiesto y habilitar el flag `MODEL_READY`.	El endpoint `/predict/treatment-plan` responde con predicciones reales calibradas.
P1 - GOOGLE	**Cuentas de Staging Google Workspace**	Crear proyecto en Google Cloud Console, habilitar Google Calendar API y Meet API, configurar credenciales OAuth2 y probar flujo en staging.	Reserva genera automáticamente sala de Meet con ID oficial y notificaciones de calendario.
P1 - AUDIO	**Pruebas de Campo con Micrófonos**	Realizar pruebas acústicas con hardware variado (laptops, auriculares de smartphone y tablets) validando el ratio de captura de 2-3 segundos.	Transcripciones fiables sin cortes por eco o cancelación acústica agresiva.
P2 - UI/UX	**Corrección de Prop DOM en Ilustraciones**	Cambiar `fetchPriority` a `fetchpriority` en `PublicIllustration.tsx` para suprimir el warning de React 18 en consola.	Consola de navegador y logs de Vitest limpios sin advertencias de atributos DOM.

6. Hoja de Ruta para Aprobación y Pase a Producción

1. **Paso 1 (Inmediato):** Solicitar confirmación del usuario para crear el commit oficial `V162_Consolidacion_Flujo_Clinico_y_Puertas_Seguridad` de acuerdo a la Regla 3 de `AGENTS.md`.
2. **Paso 2 (Validación Remota):** Hacer push a `origin/feat/sroman` para que GitHub Actions ejecute la suite completa de pruebas en el PR #151.
3. **Paso 3 (Entorno de Staging):** Configurar variables de entorno reales de Google Calendar y Decolecta en el servidor de pruebas para ensayar videollamadas con terapeutas colegiados.
4. **Paso 4 (Habilitación Asistida de IA):** Una vez validada la cohorte clínica, depositar los pesos de Random Forest en `ml-artifacts/` y cambiar el estado del predictor a disponible.

FIRMA Y RESPONSABILIDAD TÉCNICA

Informe de auditoría técnica emitido el **02 de Noviembre de 2026**.
Basado en inspección exhaustiva de código fuente, ejecución de pruebas unitarias, de enrutamiento y contratos E2E sobre el monorepo `ashakids-platform`.
Dictamen: APROBADO TÉCNICAMENTE PARA TRANSICIÓN A STAGING • PREDICCIÓN CLÍNICA PROTEGIDA POR DISEÑO ÉTICO.